AIGP Module 5: Governing AI Deployment

Comprehensive Study Notes

---

1. INTRODUCTION TO GOVERNING AI DEPLOYMENT

1.1 Purpose of Module 5

This module focuses on governance during and after AI deployment—moving from development to operational use. It covers pre-deployment planning, ongoing monitoring, incident response, vendor management, legal compliance, and maintaining systems in production.

Key Focus Areas:

- Pre-deployment planning and readiness assessments
- Deployment environment selection (cloud, on-premise, edge)
- Legal and compliance review
- Third-party and vendor management
- Ongoing monitoring and maintenance
- Model drift detection and management
- Incident response and kill switches
- Transparency and accountability mechanisms
- User rights (human review, appeals)
- Documentation and audit requirements
- Deactivation and retirement procedures

Relationship to Other Modules:

- Builds on development governance from Module 4
- Implements monitoring frameworks from Module 3
- Applies responsible AI principles from Module 2
- Prepares for legal compliance (Modules 6-7)

---

2. PRE-DEPLOYMENT PLANNING

2.1 Deployment Readiness Assessment

Purpose: Verify AI system is ready for operational deployment

Assessment Areas:

Narahari

Technical Readiness:

- All testing completed and passed (accuracy, robustness, privacy, safety, bias, adversarial)
- Performance meets specified thresholds
- Integration with existing systems validated
- Infrastructure capacity confirmed
- Scalability verified
- Security measures implemented and tested

Operational Readiness:

- Operational procedures documented
- Monitoring and alerting configured
- Incident response plans in place
- Support resources available
- Training completed for operators/users
- Backup and recovery procedures tested

Governance Readiness:

- All required approvals obtained
- Impact assessments completed and approved
- Documentation finalized (model cards, technical docs, policies)
- Compliance requirements met
- Risk mitigation measures implemented
- Stakeholder communication completed

Organizational Readiness:

- Business processes adapted to AI system
- Change management conducted
- User training completed
- Communication plans executed
- Resources allocated (budget, personnel)
- Leadership commitment confirmed

Governance Checkpoint: Formal readiness review and approval before deployment

---

Narahari

2.2 Deployment Environment Selection

Organizations must choose where to deploy AI systems:

2.2.1 Cloud-Based Deployment

Definition: Hosting AI model on cloud service providers (AWS, Azure, Google Cloud, etc.)

Characteristics:

- Shared infrastructure managed by third-party
- Pay-as-you-go pricing
- Elastic scalability
- Global accessibility
- Managed services available

Advantages:

- **Scalability**: Easy to scale up/down based on demand
- **Reduced upfront investment**: No hardware purchase required
- **Managed infrastructure**: Provider handles maintenance, updates
- **Global reach**: Deploy in multiple regions easily
- **Latest technology**: Access to cutting-edge hardware (GPUs, TPUs)
- **Rapid deployment**: Quick to provision resources
- **Disaster recovery**: Built-in redundancy and backup

Disadvantages:

- **Security and privacy risks**: Data processed by third party
- **Latency**: Network delays for remote processing
- **Vendor lock-in**: Dependence on specific provider
- **Compliance challenges**: Data residency and sovereignty concerns
- **Ongoing costs**: Can become expensive at scale
- **Less control**: Limited customization of infrastructure
- **Internet dependency**: Requires reliable connectivity

Best For:

- Variable or unpredictable workloads
- Organizations without infrastructure expertise
- Global applications

Narahari

- Rapid scaling needs
- Cost-conscious startups

Governance Considerations:

- Vendor due diligence and contracts
- Data protection agreements
- Compliance with data localization requirements
- Security controls and audits
- Service level agreements (SLAs)
- Exit strategy (avoiding lock-in)

2.2.2 On-Premise Deployment

Definition: Hosting AI model on organization's own servers and hardware

Characteristics:

- Organization owns and manages infrastructure
- Located in organization's facilities
- Full control over environment
- Capital expenditure for hardware

Advantages:

- **Greater control**: Full control over infrastructure and deployment
- **Data security**: Sensitive data stays within organization
- **Compliance**: Easier to meet data residency and sovereignty requirements
- **Customization**: Tailor infrastructure to specific needs
- **No ongoing cloud costs**: After initial investment
- **Latency**: Local processing can be faster
- **Independence**: No vendor dependency

Disadvantages:

- **Higher upfront hardware investment**: Significant capital expenditure
- **Maintenance burden**: Organization responsible for updates, repairs
- **Scalability limitations**: Capacity constrained by purchased hardware
- **Expertise required**: Need in-house infrastructure management skills
- **Slower deployment**: Time to procure and set up hardware

Narahari

- **Physical security**: Organization responsible for facility security
- **Disaster recovery**: Must implement own backup and redundancy

Best For:

- Highly regulated industries (healthcare, finance, government)
- Organizations with sensitive data
- Stable, predictable workloads
- Organizations with existing infrastructure expertise
- Data sovereignty requirements

Governance Considerations:

- Physical security of facilities
- Access controls and monitoring
- Disaster recovery and business continuity
- Hardware lifecycle management
- Capacity planning
- Energy and environmental impact

2.2.3 Edge Deployment

Definition: Hosting AI model on edge devices (smartphones, IoT devices, embedded systems) where data is generated

Characteristics:

- Processing happens locally on device
- Minimal or no cloud communication
- Limited computational resources
- Distributed across many devices

Advantages:

- **Privacy**: Data processed locally, not transmitted
- **Low latency**: No network round-trip time
- **Offline capability**: Works without internet connectivity
- **Reduced bandwidth**: No need to transmit data to cloud
- **Scalability**: Processing distributed across devices
- **Real-time processing**: Immediate response

Narahari

Disadvantages:

- **Limited computational power**: Edge devices have less processing capability
- **Limited model complexity**: Must use smaller, simpler models
- **Update challenges**: Difficult to update models on many devices
- **Inconsistent hardware**: Devices have varying capabilities
- **Testing complexity**: Many device types and configurations
- **Storage constraints**: Limited space for models
- **Battery limitations**: Energy consumption concerns for mobile devices

Best For:

- Real-time, latency-sensitive applications (autonomous vehicles, AR/VR)
- Privacy-critical applications (health monitoring, personal assistants)
- Offline or intermittent connectivity scenarios
- IoT and embedded systems
- Applications requiring immediate response

Governance Considerations:

- Device security (physical access, firmware security)
- Model update mechanisms and security
- Privacy protections for local data
- Testing across device types
- Monitoring and telemetry from edge devices
- Incident response for distributed systems

2.2.4 Hybrid Deployment

Definition: Combination of cloud, on-premise, and/or edge deployment

Examples:

- Edge processing for real-time inference, cloud for training and updates
- On-premise for sensitive data, cloud for less sensitive workloads
- Multi-cloud strategy across different providers

Advantages:

- Flexibility to optimize for different needs
- Balance of control, scalability, and cost

Narahari

- Risk mitigation through diversification

Disadvantages:

- Increased complexity
- Integration challenges
- Coordination overhead

Governance Considerations:

- Consistent policies across environments
- Data flow and security across boundaries
- Coordination of monitoring and incident response

2.3 Legal and Compliance Review

Purpose: Ensure AI system complies with all applicable laws and regulations before deployment

Review Areas:

Privacy and Data Protection:

- GDPR compliance (if processing EU data)
- CCPA/CPRA (California privacy laws)
- Other regional privacy laws
- Data minimization and purpose limitation
- Legal basis for processing
- Data subject rights mechanisms
- Cross-border data transfer compliance

AI-Specific Regulations:

- EU AI Act compliance (if applicable)
- Sector-specific AI regulations
- State/local AI laws (NYC Local Law 144, Colorado AI Act, etc.)
- Regulatory guidance and expectations

Industry-Specific Regulations:

- **Healthcare**: HIPAA (U.S.), medical device regulations (FDA), clinical decision support rules
- **Financial Services**: Fair lending laws (ECOA, FCRA), model risk management (Federal Reserve SR 11-7), consumer protection (CFPB)

Narahari

- **Employment**: Anti-discrimination laws (EEOC), bias audit requirements
- **Insurance**: Unfair discrimination laws, actuarial standards
- **Telecommunications**: FCC regulations

Anti-Discrimination Laws:

- Civil Rights Act (U.S.)
- Equal Credit Opportunity Act (ECOA)
- Fair Housing Act (FHA)
- Americans with Disabilities Act (ADA)
- Employment non-discrimination laws
- Sector-specific fairness requirements

Consumer Protection:

- FTC Act (unfair/deceptive practices)
- Consumer protection laws
- Advertising standards
- Disclosure requirements

Intellectual Property:

- Copyright considerations (training data, outputs)
- Patent issues
- Trade secret protection
- Licensing compliance

Liability and Risk:

- Product liability considerations
- Professional liability (for AI advice/recommendations)
- Terms of service and disclaimers
- Insurance coverage

Contractual Obligations:

- Third-party agreements
- Customer contracts
- Data use agreements
- Service level commitments

Governance Checkpoint: Legal sign-off required before deployment

Narahari

2.4 Unique Challenges with Proprietary AI

Definition: Use of third-party proprietary AI systems (e.g., commercial LLMs via APIs)

Challenges:

Lack of Transparency:

- No access to training data
- Unknown model architecture
- Limited understanding of decision-making
- "Black box" from user perspective

Limited Control:

- Cannot modify or fine-tune model (in many cases)
- Dependent on provider's updates and changes
- No control over model behavior
- Provider may change or discontinue service

Testing Limitations:

- Cannot audit training data for bias
- Cannot test internal mechanisms
- Limited to black-box testing of inputs/outputs
- Provider may not share performance metrics

Vendor Dependency:

- Lock-in to specific provider
- Pricing changes
- Service availability risks
- Provider's business continuity

Compliance Challenges:

- Demonstrating compliance without transparency
- Explaining decisions from opaque models
- Documenting systems with limited information
- Meeting audit requirements

Data Privacy:

- Data sent to third party for processing

Narahari

- Unclear data retention and use by provider
- Risk of data exposure
- Compliance with data localization requirements

Governance Strategies:

Enhanced Due Diligence:

- Thorough vendor assessment
- Review provider's governance practices
- Assess provider's compliance certifications
- Evaluate track record and reputation

Contractual Protections:

- Data processing agreements
- Confidentiality and security terms
- Compliance warranties
- Service level agreements (SLAs)
- Liability and indemnification
- Audit rights
- Data deletion guarantees

Black-Box Testing:

- Extensive input-output testing
- Bias testing across demographic groups
- Adversarial testing
- Performance benchmarking
- Ongoing monitoring

Documentation:

- Document what is known about system
- Record testing results
- Maintain vendor documentation
- Track model versions and updates

Risk Management:

- Accept higher residual risk or
- Choose alternative with more transparency or

Narahari

- Combine with human oversight and other controls

Monitoring:

- Continuous performance monitoring
- Track vendor updates and changes
- Monitor for degradation or drift
- User feedback analysis

---

3. THIRD-PARTY AND VENDOR MANAGEMENT

3.1 Third-Party Risk Management

Why It Matters: Using third-party AI introduces risks beyond organization's direct control

Risk Categories:

Performance Risk:

- Model doesn't meet needs
- Performance degrades over time
- Service outages and downtime

Security Risk:

- Vendor security breaches
- Inadequate security practices
- Supply chain attacks

Compliance Risk:

- Vendor non-compliance affecting organization
- Inadequate compliance controls
- Regulatory violations

Reputational Risk:

- Vendor controversies or failures
- Association with problematic practices

Operational Risk:

- Service discontinuation
- Vendor business failure
- Integration failures

Financial Risk:

Narahari

- Unexpected costs
- Pricing changes
- Vendor financial instability

3.2 Third-Party Risk Frameworks

NIST AI RMF for Third Parties:

- Apply NIST functions (Govern, Map, Measure, Manage) to vendor AI
- Assess vendor's trustworthy AI characteristics
- Document vendor governance practices

Other Frameworks:

- ISO 42001 (AI Management Systems)
- OECD AI Principles compliance
- Sector-specific frameworks (e.g., Federal Reserve SR 11-7 for model risk management in banking)

Vendor Assessment Process:

1. Vendor Selection:

- Identify requirements and criteria
- Evaluate vendor capabilities
- Assess governance maturity
- Review certifications and audits
- Check references and track record

2. Due Diligence:

- Security assessment
- Compliance verification
- Financial stability review
- Technical evaluation
- Privacy practices review
- Incident history

3. Contract Negotiation:

- Define requirements and SLAs
- Establish liability and indemnification

Narahari

- Audit rights and transparency
- Data protection terms
- Change management procedures
- Exit provisions

4. Onboarding:

- Integration and testing
- Training and documentation
- Establish communication channels
- Set up monitoring

5. Ongoing Monitoring:

- Performance tracking
- Compliance monitoring
- Relationship management
- Regular reviews and audits
- Vendor updates and changes

6. Offboarding (if needed):

- Data return or deletion
- Knowledge transfer
- Transition planning
- Contract termination

3.3 Key Vendor Agreement Terms

Data Protection and Privacy:

- Data processing agreement (DPA)
- GDPR Standard Contractual Clauses (if applicable)
- Data use restrictions (no use for vendor's purposes without consent)
- Data retention and deletion commitments
- Subprocessor disclosure and approval
- Data breach notification requirements
- Data security standards

Performance and Service Levels:

Narahari

- Service level agreements (SLAs)
    - Uptime guarantees (e.g., 99.9% availability)
    - Latency commitments
    - Accuracy or performance thresholds
- Performance metrics and reporting
- Remedies for SLA failures (credits, termination rights)

Compliance and Audit:

- Vendor compliance warranties (represents compliance with applicable laws)
- Right to audit vendor practices
- Third-party audit reports (SOC 2, ISO certifications)
- Regulatory examination cooperation
- Compliance with specific regulations (HIPAA, GDPR, etc.)

Intellectual Property:

- Ownership of inputs and outputs
- Licensing terms
- Restrictions on vendor use of customer data
- Protection of proprietary information

Liability and Indemnification:

- Liability caps and limitations
- Indemnification for vendor breaches, IP infringement, etc.
- Insurance requirements
- Allocation of risks

Transparency and Documentation:

- Model documentation (model cards, technical specs)
- Disclosure of updates and changes
- Change management procedures
- Access to information needed for governance

Incident Response:

- Incident notification requirements
- Vendor support during incidents
- Root cause analysis commitments

Narahari

- Remediation timelines

Term and Termination:

- Contract duration
- Renewal terms
- Termination rights (for cause, convenience)
- Exit assistance (data return, transition support)
- Post-termination data handling

Governance and Oversight:

- Regular meetings and reporting
- Escalation procedures
- Dispute resolution mechanisms
- Points of contact

Example Negotiation Points:

- **Data Retention**: "Vendor must delete all customer data within 30 days of termination"
- **Performance**: "Model accuracy on customer's data must remain above 90%; if below for 30 days, customer may terminate"
- **Transparency**: "Vendor must provide 60 days' notice of material model changes"
- **Audit Rights**: "Customer may audit vendor's security and compliance practices annually"

---

4. ONGOING GOVERNANCE AND MONITORING

4.1 Continuous Monitoring

Purpose: Ensure AI continues to perform as intended and identify issues early

What to Monitor:

Performance Metrics:

- Accuracy, precision, recall
- Latency and throughput
- Error rates and types
- Confidence scores distribution
- Prediction volumes

Fairness Metrics:

- Disaggregated performance by demographic groups

Narahari

- Outcome distributions
- Fairness metrics (demographic parity, equalized odds, etc.)
- Disparate impact ratios

Drift Detection:

- **Data Drift**: Input distribution changes
- **Concept Drift**: Input-output relationship changes
- **Model Drift**: Performance degradation
- Statistical tests and alerts

Security Monitoring:

- Adversarial attack attempts
- Unusual query patterns (potential extraction attempts)
- Access logs and anomalies
- Infrastructure security

Operational Metrics:

- System availability and uptime
- Resource utilization
- Error logs and exceptions
- Integration health

User Feedback:

- User satisfaction scores
- Reported issues and complaints
- Feature requests
- Usage patterns

Monitoring Tools:

- Dashboards and visualizations
- Automated alerting systems
- Logging and audit trails
- Analytics platforms
- Anomaly detection systems

Monitoring Frequency:

- Real-time: Critical metrics, security alerts

Narahari

- Daily: Performance and fairness metrics
- Weekly/Monthly: Comprehensive reviews, drift analysis
- Quarterly: Governance reviews, audits

4.2 Model Drift Management

Types of Drift (detailed):

4.2.1 Data Drift

Definition: Distribution of input data changes compared to training data

Causes:

- Population demographics shift
- User behavior changes
- Seasonality and trends
- External events (economic changes, pandemics, etc.)
- New data sources or collection methods

Example:

- Credit scoring model trained on pre-pandemic data
- During pandemic, income patterns, employment, spending change
- Input data distribution shifts significantly
- Model still works but receives "out-of-distribution" inputs

Detection Methods:

- Statistical tests (KS test, chi-square test, PSI - Population Stability Index)
- Compare current data distribution to training data
- Monitor feature distributions over time
- Automated alerts when distributions diverge

Impact:

- May reduce model performance if shift is significant
- Predictions on new distribution may be less reliable
- Can indicate concept drift may follow

4.2.2 Concept Drift

Narahari

Definition: Relationship between inputs and outputs changes; what predicted the target variable changes

Causes:

- External environment changes
- Economic conditions evolve
- Social norms shift
- Competitive landscape changes
- Regulatory changes affecting outcomes

Example:

- Credit scoring: what predicts default changes during recession
- Medical diagnosis: disease presentation or prevalence changes
- Fraud detection: fraudsters adapt tactics
- Hiring: skills valued in job market evolve

Detection Methods:

- Monitor model performance over time
- Compare predictions against actual outcomes (if feedback available)
- Track accuracy metrics trends
- Challenger model comparisons (if challenger performs better, concept may have drifted)

Impact:

- Performance degrades over time
- Model predictions become less accurate
- Requires retraining on recent data

4.2.3 Model Drift (Performance Degradation)

Definition: Model performance declines over time (can result from data drift, concept drift, or other factors)

Causes:

- Data drift or concept drift
- Software/infrastructure changes
- Model staleness (even without drift, fresher models may perform better)
- Integration issues

Narahari

- Data quality degradation

Detection Methods:

- Track performance metrics over time
- Compare to baseline and thresholds
- Regular evaluation on test sets
- A/B testing against baseline or new models

Impact:

- Reduced business value
- Increased errors and harms
- Loss of user trust

Drift Management Strategies:

Monitoring and Detection:

- Implement drift detection systems
- Set alert thresholds
- Regular drift assessments

Retraining Triggers:

- **Scheduled**: Regular retraining (e.g., quarterly, annually)
- **Performance-based**: Retrain when performance drops below threshold
- **Drift-based**: Retrain when significant drift detected
- **Event-based**: Retrain after major external events

Retraining Process:

1. Collect recent data
2. Assess data quality and representativeness
3. Retrain model on updated data
4. Validate new model performance
5. Compare to existing model
6. A/B test if improvement unclear
7. Deploy if superior
8. Document and update version

Continuous Learning:

Narahari

- Online learning (model updates incrementally with new data)
- Active learning (model identifies informative examples for labeling)
- Requires careful governance to prevent drift in wrong direction

Adaptive Models:

- Models designed to adapt to changes
- Ensemble methods combining multiple models
- Transfer learning for new domains

Governance:

- Documented drift monitoring strategy
- Clear retraining triggers and procedures
- Approval process for deploying updated models
- Testing requirements for new versions
- Version control and rollback capability

4.3 Red Teaming

Definition: Adversarial testing by dedicated team attempting to find vulnerabilities, weaknesses, and failure modes in deployed AI systems

Purpose:

- Identify security vulnerabilities
- Discover unexpected behaviors
- Test robustness and safety
- Validate safeguards and controls
- Find biases and fairness issues
- Assess misuse potential

Red Team Composition:

- Security experts
- AI/ML specialists
- Domain experts
- Ethical hackers
- Diverse perspectives

Red Teaming Activities:

Narahari

Adversarial Attacks:

- Generate adversarial examples
- Attempt model extraction or inversion
- Test data poisoning vectors
- Evasion techniques

Prompt Injection (for LLMs):

- Attempts to override system instructions
- Jailbreaking (bypassing safety controls)
- Extraction of training data
- Generating prohibited content

Bias and Fairness Testing:

- Systematic testing across demographics
- Identify discriminatory patterns
- Test edge cases for vulnerable populations

Safety Testing:

- Push system to failure modes
- Test in extreme or unusual scenarios
- Assess harm potential
- Validate safety mechanisms (kill switches, overrides)

Misuse Scenarios:

- Explore dual-use potential
- Test for malicious applications
- Assess manipulation risks

Process:

1. Define scope and objectives
2. Assemble red team
3. Conduct adversarial testing
4. Document findings (vulnerabilities, attack vectors, impacts)
5. Prioritize issues by severity
6. Remediate vulnerabilities
7. Re-test after fixes

Narahari

8. Report results to stakeholders
9. Update defenses and monitoring

Ongoing Red Teaming:

- Regular schedule (e.g., annually, after major updates)
- Continuous testing for high-risk systems
- External red teams for independence

Governance:

- Red teaming required for high-risk AI
- Documented findings and remediation
- Approval to deploy only after critical issues resolved
- Responsible disclosure for external red teams

4.4 Bug Bounties

Definition: Programs offering rewards to external security researchers who discover and report vulnerabilities in AI systems

Purpose:

- Leverage external expertise
- Incentivize responsible disclosure
- Identify issues internal teams may miss
- Continuous security testing
- Build trust through transparency

Scope Definition:

- What systems are in scope
- What types of issues qualify (security, bias, safety, etc.)
- What activities are permitted
- Off-limits areas and prohibited actions

Reward Structure:

- Severity-based rewards (e.g., critical: $10,000, high: $5,000, medium: $1,000, low: $500)
- Recognition (hall of fame)
- Responsible disclosure requirements

Process:

Narahari

1. Researcher discovers vulnerability
2. Reports through designated channel
3. Organization triages and validates
4. Communicates with researcher
5. Remediates issue
6. Awards bounty
7. Public disclosure (after fix, if appropriate)

Governance:

- Legal framework (terms, liability protections for researchers)
- Triage and response procedures
- Escalation for critical issues
- Disclosure timeline and policy
- Integration with incident response

Examples:

- Google's Vulnerability Reward Program (includes AI/ML systems)
- Bug bounties for model robustness, fairness issues
- Red team + bug bounty combination

4.5 Conformity Assessments

Definition: Process of demonstrating AI system meets specific standards or regulatory requirements

Context: Required under EU AI Act for high-risk systems (Article 43)

Types:

Self-Assessment (Internal Conformity Assessment):

- Organization evaluates own compliance
- Follows prescribed procedures
- Documents evidence
- Declares conformity
- Less costly but less credible

Third-Party Assessment (by Notified Body):

- Independent organization evaluates compliance

Narahari

- More rigorous and credible
- Required for certain high-risk categories (e.g., biometrics)
- Leads to certification

Process:

1. Identify applicable requirements
2. Gather evidence of compliance
3. Conduct assessment (self or third-party)
4. Document findings
5. Address any gaps
6. Obtain certification or declaration
7. Maintain evidence for audits

Conformity Assessment for AI:

- Technical documentation review
- Risk management system assessment
- Data governance evaluation
- Testing and validation evidence
- Quality management system audit
- Ongoing compliance monitoring

Timing:

- Before placing on market (pre-deployment)
- After substantial modifications
- Periodic re-assessment

Governance:

- Maintain documentation for conformity assessment
- Prepare for third-party audits
- Update as system changes
- Retain evidence (EU AI Act: 10 years)

---

5. TRANSPARENCY AND ACCOUNTABILITY

5.1 Model Cards and Documentation

Deployment-Specific Additions to Model Cards:

Narahari

- Deployment date and version
- Deployment environment (cloud, on-premise, edge)
- Operational parameters and configurations
- Monitoring approach
- Update history
- Known issues in production
- Incident history

Accessibility:

- Available to relevant stakeholders
- Internal users, oversight bodies
- External transparency (public model cards where appropriate)
- Regulators upon request

5.2 Transparency Requirements

Disclosure of AI Use:

- **To Users**: Inform when interacting with AI
- **To Affected Individuals**: Notify when AI makes decisions about them
- **To Regulators**: Required disclosures and registrations
- **To Public**: Transparency reports, AI use disclosures

Information to Provide:

- Fact that AI is being used
- Purpose of AI system
- Type of decisions made
- Data used
- How to seek human review or appeal
- Contact information

Examples:

- Chatbots: “You’re chatting with an AI assistant”
- Automated decisions: “This decision was made using automated processing”
- Recommendation systems: “These recommendations are generated by AI”

EU AI Act Requirements (Limited Risk - Article 52):

Narahari

- Users must be informed they're interacting with AI
- Deepfakes must be labeled
- Emotion recognition or biometric categorization must be disclosed
- Transparency obligations for AI-generated content

5.3 Disclosure Obligations

Regulatory Disclosures:

- EU AI Act: Registration in EU database for high-risk systems
- NYC Local Law 144: Bias audits must be published
- California: Generative AI training data transparency
- Sector-specific reporting (e.g., financial regulators, health authorities)

Stakeholder Disclosures:

- Customers and users
- Employees (if AI affects them)
- Investors and shareholders
- Board and executive reporting

Public Transparency:

- AI transparency reports (similar to privacy reports)
- Voluntary disclosures of AI principles and governance
- Research publications and findings
- Incident disclosures (when appropriate)

Balancing Transparency and Confidentiality:

- Protect trade secrets and intellectual property
- Security considerations (don't disclose vulnerabilities)
- Privacy of training data and individuals
- Redact sensitive information in public disclosures

5.4 AI Registries and Databases

Internal AI Inventory: (from Module 3)

- Comprehensive catalog of all AI systems
- Risk scores and categories

Narahari

- Ownership and accountability
- Update and review schedules

EU AI Act Database (Public):

- High-risk AI systems must be registered
- Before placing on market
- Information available to public and regulators
- Includes provider, system description, intended purpose, risk classification

Purpose:

- Regulatory oversight
- Public awareness
- Accountability
- Market surveillance

Information Required:

- Provider identification
- System description and type
- Intended purpose and users
- Risk classification
- Conformity assessment information
- Instructions for use

5.5 Audit Trails and Logging

Purpose: Enable accountability, troubleshooting, and compliance verification

What to Log:

Input Data:

- Inputs to AI system (subject to privacy constraints)
- Timestamps
- User or source identifiers

Model Outputs:

- Predictions or decisions
- Confidence scores
- Timestamps

Narahari

System Actions:

- Decisions made
- Actions taken based on AI
- Human overrides or interventions

Access and Usage:

- Who accessed system and when
- Configuration changes
- Model updates or deployments

Incidents and Errors:

- Errors and exceptions
- Incident reports
- Investigation findings

EU AI Act Logging Requirements (Article 12):

- High-risk AI must have automatic recording of events (logs)
- Enable traceability
- Appropriate to nature and risks
- Retained for period appropriate to intended purpose (minimum to meet regulatory requirements)

Governance:

- Log retention policies (balance auditability with storage costs and privacy)
- Access controls for logs (sensitive information)
- Regular review and analysis
- Integration with monitoring systems
- Use in incident investigation

---

6. USER RIGHTS AND HUMAN OVERSIGHT

6.1 Right to Human Review and Intervention

GDPR Article 22: Right not to be subject to solely automated decision-making with significant effects

Components:

- Right to obtain human intervention
- Right to express point of view

Narahari

- Right to contest the decision
- Right to obtain an explanation

When It Applies:

- Automated decision with legal or similarly significant effect
- Examples: Credit decisions, employment decisions, insurance, benefits eligibility

Exceptions (automated decisions allowed if):

- Necessary for contract performance
- Authorized by law with safeguards
- Based on explicit consent

Implementation:

- Provide mechanism for requesting human review
- Ensure human reviewer has authority to change decision
- Train human reviewers (avoid automation bias)
- Document human review process and outcomes
- Clear communication to individuals about their rights

Beyond GDPR:

- Good practice for high-stakes AI decisions regardless of legal requirement
- Builds trust and fairness
- Enables error correction
- Demonstrates human-centricity

6.2 Right to Explanation

Concept: Individuals have right to understand AI decisions affecting them

Legal Basis:

- GDPR: Right to meaningful information about logic involved in automated decision-making
- Other laws and regulations increasingly require explainability
- Sector-specific requirements (e.g., fair lending, employment)

What to Explain:

- That AI was used
- Purpose of AI system

Narahari

- Significance and envisaged consequences
- Logic and factors considered
- Why this specific decision for this individual

Explanation Formats:

- Natural language explanations
- Feature importance for this decision
- Counterfactual: what would need to change for different outcome
- Visualization or examples

Challenges:

- Black-box models difficult to explain
- Balance detail and understandability
- Different audiences need different explanations
- Explanation may not be "complete" understanding

Implementation:

- Design explanation capability into system
- Test explanations with users for comprehension
- Provide explanations proactively or upon request
- Train staff to answer questions
- Document explanation methodology

6.3 Appeals and Redress Mechanisms

Purpose: Enable individuals to challenge AI decisions and seek remedies

Components:

Appeal Process:

- Clear procedure for filing appeals
- Reasonable timelines for review
- Human review of appealed decisions
- Authority to overturn or modify decisions
- Communication of appeal outcome and rationale

Redress Options:

- Correction of incorrect decisions

Narahari

- Compensation for harms
- Account reinstatement or access restoration
- Deletion of data or outputs
- Public apology or acknowledgment

Access:

- Easy-to-find information about appeal rights
- Simple process (not overly burdensome)
- Free or low-cost
- Accessible to all users

Independence:

- Reviewers should be different from original decision-makers
- Avoid conflicts of interest
- Objective assessment

Documentation:

- Track appeals and outcomes
- Analyze patterns (frequent appeals may indicate systemic issues)
- Learn and improve from appeals
- Report on appeals metrics

Governance:

- Documented appeal procedures
- Training for appeal reviewers
- Oversight of appeal process
- Regular review of appeal patterns and outcomes

6.4 Human-in-the-Loop, On-the-Loop, Out-of-the-Loop

Human-in-the-Loop (HITL):

Definition: Human reviews and approves each AI decision before it's implemented

Characteristics:

- AI makes recommendation
- Human makes final decision
- Human can override AI

Narahari

When Appropriate:

- High-stakes decisions (life/death, significant rights impact)
- High-risk AI systems
- Novel or edge cases
- When AI confidence is low

Challenges:

- Scalability (human bandwidth)
- Automation bias (humans over-rely on AI)
- Slows decision-making
- Human error still possible

Governance:

- Clear criteria for human review
- Training to avoid automation bias
- Document human decisions and overrides
- Monitor override patterns

Human-on-the-Loop (HOTL):

Definition: AI makes and implements decisions, but human monitors and can intervene

Characteristics:

- AI acts autonomously
- Human oversees
- Human can override or halt
- Human intervenes when needed (alerts, unusual cases)

When Appropriate:

- Medium-risk decisions
- High-volume, time-sensitive decisions
- When HITL not scalable
- Operational AI systems with established performance

Challenges:

- Requires effective monitoring systems
- Vigilance decrements (humans lose attention over time)

Narahari

- May not catch issues before harm occurs

Governance:

- Effective monitoring and alerting
- Clear intervention criteria and procedures
- Training for monitors
- Rotation to maintain vigilance
- Track interventions and reasons

Human-out-of-the-Loop (HOOTL):

Definition: AI operates fully autonomously without human involvement in decisions

Characteristics:

- No human review or approval
- AI makes and implements decisions
- Humans may monitor aggregate metrics but not individual decisions

When Appropriate:

- Low-risk decisions
- High-volume, low-stakes (e.g., spam filtering, product recommendations)
- Real-time decisions where human review impossible (e.g., autonomous vehicle split-second reactions)

Challenges:

- No human safeguard
- Risk of unanticipated harms at scale
- Accountability questions

Governance:

- Allowed only for low-risk use cases
- Extensive pre-deployment testing
- Robust ongoing monitoring
- Ability to halt system if issues detected
- Post-hoc human review (auditing)

Choosing Appropriate Level:

Narahari

- Based on risk assessment (severity of potential harms)
- Regulatory requirements
- Operational feasibility
- User expectations and trust

---

7. INCIDENT RESPONSE AND MANAGEMENT

7.1 Incident Response Planning

Incident Definition: AI failure, malfunction, harm, or significant performance issue requiring response

Types of AI Incidents:

- Performance failures (significant accuracy drop, errors)
- Security breaches (adversarial attacks, data breaches)
- Bias and discrimination (unfair outcomes discovered)
- Safety issues (harm or near-harm)
- Privacy violations (unauthorized data access/use)
- Compliance violations
- Reputational issues (public backlash, media coverage)

Incident Response Plan Components:

1. Detection and Identification:

- Monitoring and alerting systems
- User reports and feedback channels
- Internal discovery
- External notification (researchers, regulators, media)

2. Classification and Triage:

- Severity assessment (critical, high, medium, low)
- Impact determination (who/what affected, scale)
- Urgency and priority
- Incident categorization (type of issue)

3. Containment:

- Immediate actions to prevent further harm
- May include disabling system, rolling back, restricting access

Narahari

- Preserve evidence for investigation

4. Investigation:

- Root cause analysis (why did this happen)
- Scope assessment (full extent of impact)
- Data and log review
- Stakeholder interviews
- Technical forensics

5. Notification:

- **Internal**: Leadership, legal, affected teams
- **External**: Affected individuals, regulators (if required), public (if appropriate)
- Timelines (e.g., GDPR: 72 hours for breach notification)
- Content (what happened, impact, remediation)

6. Remediation:

- Fix underlying issue (technical, process, policy)
- Correct erroneous decisions
- Compensate or make whole affected individuals
- Restore systems to safe operation

7. Communication:

- Transparent communication with stakeholders
- Regular updates
- Post-incident report
- Public statement (if appropriate)

8. Recovery:

- Resume normal operations
- Validate fix effectiveness
- Monitor for recurrence

9. Post-Incident Review:

- Lessons learned
- What went well, what didn't
- Recommendations for improvement
- Update policies, procedures, systems

Narahari

10. Documentation:

- Incident timeline
- Actions taken
- Decisions and rationale
- Outcomes and impacts
- Follow-up actions

7.2 Serious Incident Reporting

EU AI Act Requirements (Article 73):

Serious Incident Definition:

- Incident leading to death or serious harm to health, property, environment
- Incident causing serious and irreversible disruption of critical infrastructure
- Breach of fundamental rights obligations

Reporting Obligations:

- **Who Reports**: Providers of high-risk AI systems
- **To Whom**: Market surveillance authorities in Member State
- **When**: Immediately upon awareness (within 15 days, or immediately if urgent)
- **Content**: Nature of incident, AI system involved, impacts, corrective actions

Provider Responsibilities:

- Immediate investigation
- Corrective actions
- Notification to affected parties
- Cooperation with authorities

Records:

- Maintain incident records
- Documentation for authorities
- Track and analyze incident patterns

7.3 Kill Switches and Emergency Stops

Definition: Capability to immediately halt or disable AI system in emergency

Purpose:

Narahari

- Prevent further harm during incident
- Enable rapid response to serious issues
- Safety mechanism for high-risk AI
- Regulatory requirement in some contexts (EU AI Act Article 14: human oversight includes stop button)

Types:

Hard Kill Switch:

- Physical or direct system shutdown
- Immediate cessation of operations
- May result in abrupt stop (for safety-critical systems, may need graceful degradation)

Soft Kill Switch:

- Gradual shutdown or degradation
- Allows current operations to complete
- Less disruptive

Partial Disabling:

- Disable specific features or functions
- Maintain core operations while removing problematic components

Design Considerations:

- **Accessibility**: Authorized personnel can quickly activate
- **Reliability**: Must work even when AI system fails
- **Independence**: Not dependent on AI system's operation
- **Clear Authority**: Who can activate, under what circumstances
- **Testing**: Regular testing that kill switch works

Governance:

- Document kill switch procedures
- Train authorized personnel
- Clear activation criteria
- Incident response integration
- Testing schedule (without disrupting operations)
- Post-activation procedures (investigation, remediation, restart)

Narahari

8. DEACTIVATION AND RETIREMENT

8.1 Deactivation Procedures

When to Deactivate:

- Serious incident requiring immediate stop
- Unresolvable performance issues
- Compliance violations
- End of useful life or business need
- Replacement by newer system
- Strategic decision to discontinue

Deactivation Process:

1. Decision and Approval:

- Document rationale
- Obtain appropriate approvals
- Consider alternatives

2. Planning:

- Impact assessment (who/what affected)
- Timeline and transition plan
- Communication plan
- Data handling plan

3. Communication:

- Notify affected users and stakeholders
- Provide advance notice (where possible)
- Explain alternatives or replacements

4. Data Management:

- Backup necessary data
- Retention according to policy and legal requirements
- Secure deletion of data no longer needed
- Transfer data to successor system (if applicable)

5. System Decommissioning:

- Graceful shutdown
- Disable access

Narahari

- Remove from production
- Archive code and configurations (for records)

6. Documentation:

- Deactivation date and reason
- Final state and performance
- Data disposition
- Lessons learned

8.2 Retirement and Archival

AI System Lifecycle End:

- Formal retirement when no longer in use
- Transition from operational to archived state

Archival Requirements:

- Retain documentation for regulatory periods (e.g., EU AI Act: 10 years)
- Model versions and code
- Training data (if retention allowed/required)
- Logs and audit trails
- Incident reports
- Compliance documentation

Knowledge Transfer:

- Document lessons learned
- Share insights with organization
- Inform future AI development

Legal and Regulatory:

- Meet retention requirements
- Prepare for potential audits or litigation
- Data deletion where required (e.g., GDPR erasure requests)

---

9. RETRIEVAL-AUGMENTED GENERATION (RAG)

9.1 What is RAG?

Narahari

Definition: Technique for enhancing generative AI (especially LLMs) by retrieving relevant information from external knowledge sources before generating responses

How It Works:

1. User query received
2. System retrieves relevant documents/information from knowledge base
3. Retrieved information provided to LLM as context
4. LLM generates response based on query AND retrieved information
5. Response grounded in retrieved documents

Purpose:

- Reduce hallucinations (false information)
- Provide up-to-date information (knowledge base can be updated without retraining)
- Ground responses in specific organizational knowledge
- Enable citations and sources
- Improve accuracy and relevance

Components:

- **Knowledge Base**: Database of documents, information
- **Retrieval System**: Search/retrieval mechanism (vector search, keyword search)
- **Generative Model**: LLM that generates responses
- **Integration Layer**: Combines retrieval and generation

Use Cases:

- Customer support chatbots (access to product documentation, FAQs)
- Legal/regulatory research (retrieve relevant statutes, cases)
- Medical information systems (access to medical literature)
- Internal knowledge management (company policies, procedures)

9.2 Governance Considerations for RAG

Data Governance:

- Quality and accuracy of knowledge base (RAG only as good as retrieved information)
- Provenance and trustworthiness of sources
- Data privacy (retrieved documents may contain sensitive information)
- Access controls (ensure retrieval respects permissions)

Narahari

- Data updates and maintenance

Retrieval Quality:

- Relevance of retrieved information (poor retrieval = poor generation)
- Biases in retrieval ranking
- Completeness (important information not missed)
- Testing and validation of retrieval

Generation Quality:

- Model may still hallucinate even with retrieval
- May ignore or misinterpret retrieved information
- Ensure generation consistent with sources

Transparency:

- Provide citations and sources for generated content
- Enable users to verify information
- Disclose when RAG is used

Testing:

- Test retrieval + generation pipeline
- Validate against ground truth
- Check for hallucinations despite retrieval
- Test edge cases (no relevant documents, contradictory sources)

Monitoring:

- Track retrieval quality over time
- Monitor generation fidelity to sources
- User feedback on accuracy

Advantages Over Pure LLM:

- More accurate and grounded
- Easier to update knowledge
- Can provide citations
- Better for specific domains

Disadvantages:

- Complexity (two systems to manage)
- Retrieval can be slow

Narahari

- Retrieval quality critical
- Still potential for errors

---

10. FUNCTION CREEP

10.1 Definition

Function Creep: Gradual expansion of AI system use beyond its original purpose, often without appropriate governance review

Also Called: Scope creep, mission creep

10.2 How Function Creep Happens:

Examples:

- AI trained for one use case applied to different context
- Features added incrementally over time
- Initial low-risk use expands to high-risk application
- System shared across departments for different purposes

Specific Example:

- Facial recognition deployed for employee building access (low-risk)
- Gradually expanded to track employee movements and productivity (high-risk)
- Originally designed for security, now used for performance management
- Significantly increased privacy and fairness risks

10.3 Risks of Function Creep:

Governance Gaps:

- New use not subject to original approval and review process
- Risks not properly assessed
- Impact assessments not updated
- Stakeholders not consulted

Increased Harms:

- System designed for low-risk use applied to high-risk context
- Safeguards insufficient for new use
- Unintended populations affected

Narahari

Legal and Compliance:

- Violation of purpose limitation (GDPR)
- Non-compliance with use-specific regulations
- Consent issues (data used for different purpose)

Trust and Reputation:

- Users feel deceived or surveilled
- Erosion of trust
- Public backlash

10.4 Preventing Function Creep:

Clear Use Case Boundaries:

- Document intended purpose explicitly
- Define in-scope and out-of-scope uses
- Communicate boundaries to all stakeholders

Purpose Limitation:

- Use data and AI only for stated purposes
- New purposes require new assessment and approval

Governance for Changes:

- Change management process
- New use cases require governance review
- Re-assessment of risks
- Updated impact assessments

Monitoring and Audits:

- Track actual use vs. intended use
- Detect unauthorized expansion
- Regular reviews

Technical Controls:

- Access controls limit who can use system and for what
- Logging tracks use patterns
- Alerts for unusual use

Training and Awareness:

Narahari

- Educate users about appropriate use
- Consequences for misuse

---

11. KEY DEFINITIONS FOR MODULE 5

Deployment Environment: Where AI is hosted—cloud, on-premise, or edge.

Cloud-Based Deployment: Hosting AI on third-party cloud service providers; scalable but with security/privacy considerations.

On-Premise Deployment: Hosting AI on organization's own infrastructure; greater control and security but higher upfront investment.

Edge Deployment: Hosting AI on local devices where data is generated; privacy and latency benefits but limited computational power.

Third-Party Risk Management: Process of assessing and managing risks from AI vendors and providers.

Service Level Agreement (SLA): Contract terms specifying performance guarantees (uptime, latency, etc.) and remedies.

Data Drift: Input data distribution changes compared to training data.

Concept Drift: Relationship between inputs and outputs changes over time.

Model Drift: Model performance degrades over time.

Red Teaming: Adversarial testing by dedicated team to find vulnerabilities and weaknesses.

Bug Bounty: Program rewarding external researchers for discovering and reporting vulnerabilities.

Conformity Assessment: Process demonstrating AI meets specific standards or regulatory requirements.

Kill Switch: Capability to immediately halt or disable AI system in emergency.

Model Card: Standardized documentation for AI models (expanded in deployment to include operational information).

Retrieval-Augmented Generation (RAG): Technique enhancing generative AI by retrieving relevant information before generating responses.

Function Creep: Gradual expansion of AI use beyond original purpose without appropriate governance.

Human-in-the-Loop (HITL): Human reviews and approves each AI decision before implementation.

Human-on-the-Loop (HOTL): AI acts autonomously but human monitors and can intervene.

Human-out-of-the-Loop (HOOTL): AI operates fully autonomously without human involvement in individual decisions.

Narahari

Right to Human Review: Right to obtain human intervention in automated decision-making.

Right to Explanation: Right to understand AI decisions affecting an individual.

Appeals and Redress: Mechanisms enabling individuals to challenge AI decisions and seek remedies.

Serious Incident: Under EU AI Act, incident causing death, serious harm, or fundamental rights breach, requiring reporting.

Audit Trail: Logged records of AI inputs, outputs, decisions, and actions for accountability and troubleshooting.

Deactivation: Process of stopping AI system operation.

Retirement: Formal end of AI system lifecycle with archival of documentation.

---

12. STUDY TIPS FOR MODULE 5

Key Concepts to Master:

1. ✅ Understand **three deployment environments** (cloud, on-premise, edge) with advantages/disadvantages
2. ✅ Know **third-party risk management** including vendor assessment and key contract terms
3. ✅ Master **three types of drift** (data, concept, model) and detection/management
4. ✅ Understand **red teaming** and **bug bounties** for ongoing security
5. ✅ Know **user rights** (human review, explanation, appeals)
6. ✅ Master **three levels of human oversight** (in-loop, on-loop, out-of-loop)
7. ✅ Understand **incident response** process and **serious incident reporting** (EU AI Act)
8. ✅ Know **kill switches** and when required
9. ✅ Understand **RAG** (Retrieval-Augmented Generation) and governance
10. ✅ Know **function creep** and how to prevent it

Common Pitfalls to Avoid:

- ❌ Confusing deployment environments (especially cloud vs. on-premise tradeoffs)
- ❌ Not understanding difference between drift types
- ❌ Mixing up human oversight levels (in-loop vs. on-loop)
- ❌ Forgetting serious incident reporting requirements (EU AI Act Article 73)
- ❌ Not knowing when DPIAs required before deployment
- ❌ Confusing conformity assessment types (self vs. third-party)

Narahari

Practical Application:

- For each deployment environment, list appropriate use cases
- Design vendor assessment checklist
- Create drift monitoring strategy with triggers
- Develop incident response plan for bias incident
- Outline user rights implementation for a system
- Map human oversight level to different risk scenarios

Memorization Aids:

Three Deployment Environments (C-O-E):

- **C**loud (scalable, third-party, security risks)
- **O**n-premise (control, upfront cost, compliance easier)
- **E**dge (privacy, latency, limited power)

Three Types of Drift (D-C-M):

- **D**ata drift (input distribution changes)
- **C**oncept drift (input-output relationship changes)
- **M**odel drift (performance degrades)

Three Human Oversight Levels:

- **In-the-loop**: Human approves EACH decision (high-stakes)
- **On-the-loop**: Human MONITORS, can intervene (medium-risk)
- **Out-of-the-loop**: AI autonomous, human ABSENT from individual decisions (low-risk)

Incident Response Steps (D-C-I-N-R-C-R-D):

- **D**etection
- **C**lassification
- **C**ontainment
- **I**nvestigation
- **N**otification
- **R**emediation
- **C**ommunication
- **R**ecovery
- Post-incident review
- **D**ocumentation

Narahari

Key Vendor Contract Terms (D-P-C-I-L-T):

- **D**ata protection (DPA, retention, deletion)
- **P**erformance (SLAs, metrics)
- **C**ompliance (warranties, audit rights)
- **I**ntellectual property (ownership, licensing)
- **L**iability (caps, indemnification)
- **T**ransparency (documentation, changes)

Narahari